

ISO/IEC 27001:2022 Uyumluluğu için Yazılım Geliştirme ve ISMS Rehberi

Proje: GD-PMS (Power Management System) **Mimari:** Nx Monorepo (Backend Servisler + Desktop App + React Frontend + Paylaşılan Paketler) **Dil:** TypeScript **Monorepo Adı:** gd-pms-monorepo **Versiyon:** 1.0
Referans Standart: ISO/IEC 27001:2022 (Edition 3, 2022-10) **İlgili Döküman:** [docs/nis-2.md](#)

Bu belge, ISO/IEC 27001:2022 Bilgi Güvenliği Yönetim Sistemi (BGYS/ISMS) standardı kapsamında Nx monorepo yapısındaki GD-PMS yazılımının geliştirme ve işletim sürecinde alınması gereken teknik, süreçsel ve yönetsel önlemleri tanımlamaktadır. Belge aynı zamanda [NIS2 uyumluluk dökümanı](#) ile örtüşen ve ayrılan noktaları göstermektedir.

NIS2 ve ISO/IEC 27001:2022 Benzerlik Analizi

Genel Bakış

NIS2 Direktifi ve ISO 27001 aynı hedefe (bilgi güvenliği) farklı açılardan yaklaşır:

Boyut	NIS2	ISO/IEC 27001:2022
Türü	AB Direktifi (yasal zorunluluk)	Uluslararası standart (gönüllü sertifikasyon)
Kapsamı	Kritik altyapı ve temel hizmet sektörleri	Tüm sektörler, her ölçekte kuruluş
Yaklaşımı	Teknik kontroller ve olay raporlama odaklı	Yönetim sistemi (ISMS) — PUKO döngüsü
Denetim	Uygunluk değerlendirmesi (NCA onaylı)	Akredite belgelendirme kuruluşu tarafından sertifikasyon
Yaptırım	İdari para cezası (AB üyesi ülkelerde)	Sertifika askıya alma/iptal (ticari itibar kaybı)
Kontroller	Madde 21 (risk yönetimi tedbirleri)	Annex A — 93 kontrol (4 tema, 2022)
Güncelleme	Ulusal yasaların yürürlüğe girişine bağlı	Her 5-7 yılda bir revizyon

Örtüşme Oranı

NIS2 dökümanındaki 17 adım ile ISO 27001:2022 Annex A kontrolleri arasındaki örtüşme:

Örtüşme Durumu	Açıklama	Yüzde
Doğrudan karşılıyor	NIS2'deki adım birebir ISO kontrolünü sağlıyor	~%45
Kısmen karşılıyor	NIS2 adımı mevcut ama ISO ek gereksinimler getiriyor	~%25
ISO'ya özel	NIS2 dökümanında hiç yer almayan, sadece ISO'nun istediği kontroller	~%30

Aşağıdaki tablo, NIS2 dökümanındaki her adımın hangi ISO 27001:2022 Annex A kontrolünü karşıladığını göstermektedir:

NIS2 Adımı	ISO 27001:2022 Annex A Kontrolleri	Durum
Adım 1 — Quality Profile	A.8.8 Technical vulnerability management, A.8.29 Security testing in dev	✓ Doğrudan
Adım 2 — Tamper-evident kuralı	A.8.15 Logging, A.8.16 Monitoring activities	✓ Doğrudan
Adım 3 — Hard-coded secrets	A.5.16 Identity management, A.8.12 Data leakage prevention	✓ Doğrudan
Adım 4 — Quality Gate	A.8.8, A.8.29, A.8.31 Separation of dev/test/prod	✓ Doğrudan
Adım 5 — TamperEvidentLogger	A.8.15 Logging, A.8.16, A.8.17 Clock synchronization	✓ Doğrudan
Adım 6 — Logger entegrasyonu	A.8.15, A.8.16	✓ Doğrudan
Adım 7 — VerifyChain testi	A.8.15, A.8.29	✓ Doğrudan
Adım 8 — Health check endpoint	A.8.16 Monitoring activities	⚠ ISO ayrıca kapasite izleme ister
Adım 9 — useAuditLog hook	A.5.15 Access control, A.8.15	⚠ ISO ayrıca ayrıcalıklı erişim loglaması ister
Adım 10 — Simülatör logları	A.8.15	✓ Doğrudan
Adım 11 — Nx + SonarQube CI	A.8.31, A.8.32	✓ Doğrudan
Adım 12 — @nis2-security testleri	A.8.29	✓ Doğrudan
Adım 13 — SBOM + Trivy	A.8.8, A.8.9 Configuration management	✓ Doğrudan
Adım 14 — Playwright güvenlik testleri	A.8.29	✓ Doğrudan
Adım 15 — Sürüm Güvenlik Beyanı	Doğrudan eşleşen kontrol yok	⚠ ISO yönetim gözden geçirme ile kısmen karşılanır
Adım 16 — SSDF belgesi	A.8.25 Secure development life cycle	⚠ ISO ayrıca tüm SDLC fazlarını kapsar
Adım 17 — Pentest	A.8.29, A.8.30 Outsourced development	✓ Doğrudan

NIS2 Dökümanında Yer Almayan, ISO 27001'in Zorunlu Kıldığı Başlıca Alanlar

1. **Üst yönetim taahhüdü** (Clause 5.1) — imzalı politika, kaynak tahsisi
2. **Formel risk değerlendirme** (Clause 6.1.2) — metodoloji, risk işleme planı
3. **Varlık envanteri** (A.5.9) — tüm bilgi varlıkları, sahipleri, sınıflandırması
4. **Erişim kontrolü** (A.5.15, A.5.18, A.8.2-A.8.7) — politika, ayrıcalıklı erişim yönetimi
5. **Kriptografik kontroller** (A.8.24) — TLS/HTTPS her yerde, anahtar yönetimi
6. **İletişim güvenliği** (A.8.20, A.8.22, A.8.23) — ağ segmentasyonu, security headers
7. **Yedekleme** (A.8.13) — düzenli, testli, şifrelenmiş
8. **İş sürekliliği** (A.5.29, A.5.30) — BCP, DRP, tatbikatlar
9. **Olay müdahale** (A.5.24-A.5.28) — prosedür, sorumluluklar, raporlama
10. **Tedarikçi güvenliği** (A.5.19-A.5.22) — değerlendirme, sözleşme maddeleri
11. **Yetkinlik ve farkındalık** (A.6.3, A.6.8) — eğitim programı
12. **İç denetim** (Clause 9.2) — yıllık denetim programı ve raporlama
13. **Yönetim gözden geçirme** (Clause 9.3) — periyodik üst yönetim toplantısı
14. **Yasal uyumluluk** (A.5.31-A.5.36) — fikri mülkiyet, kişisel veri, mevzuat takibi

Mevcut Durum ve Mimari Özet

Bileşen	Teknoloji	Durum
Monorepo Yönetimi	Nx	Kurulu
Paket Yöneticisi	Bun	Kurulu
Backend Servisler	Node.js / Fastify (data-service, device-service, web-service, demo-backend)	Geliştirme devam ediyor
Desktop Uygulama	Electron (desktop, container-desktop)	Geliştirme devam ediyor
Web Frontend	React (container-web, field, superadmin)	Geliştirme devam ediyor
Paylaşılan Paketler	core, shared-types, shared-utils, ui, device-library	Mevcut
Kod Kalitesi	SonarQube (SonarCloud)	Entegre
Test Çerçevesi	Vitest (birim), Playwright (E2E)	Mevcut
CI/CD	GitHub Actions	Mevcut
Konteyner	Docker + Docker Compose	Mevcut
Veritabanı	TimescaleDB (PostgreSQL)	Mevcut
Mesaj Kuyruğu	Redis + BullMQ	Mevcut
Kimlik Doğrulama	JWT (jose, HS256)	Mevcut
Yetkilendirme	RBAC middleware (admin/teknik/guest/boss)	Mevcut
Şifreleme (transit)	Yok — tüm iletişim düz HTTP/WS	Eksik
Security Headers	Yok — ne Fastify ne nginx	Eksik

Bileşen	Teknoloji	Durum
Rate Limiting	Yok	Eksik
Docker Hardening	Yok — tüm konteynerler root	Eksik
Yedekleme	Yok — manuel	Eksik
ISMS Dokümantasyonu	Yok	Eksik

Faz 1: ISMS Temelleri (Yönetimsel Kurulum)

Bu faz, ISO 27001'in yönetim sistemi gerekliliklerini karşılayan belge ve süreçlerin oluşturulmasını kapsar. Geliştirme faaliyeti barındırmaz; dokümantasyon ve süreç tanımı ağırlıklıdır.

Adım 1: Bilgi Güvenliği Politikasının Hazırlanması ve İmzalatılması

Amaç: ISO 27001 Clause 5.2 gereği üst yönetimin bilgi güvenliğine olan taahhüdünün yazılı hale getirilmesi.

Yapılacaklar:

- [docs/policies/](#) dizini oluşturulur.
- Aşağıdaki başlıkları içeren [bilgi-guvenligi-politikasi.md](#) hazırlanır:
 - Amaç ve kapsam (GD-PMS yazılım geliştirme, işletim ve destek süreçleri)
 - Üst yönetim taahhüdü (kaynak tahsisi, sürekli iyileştirme)
 - Bilgi güvenliği hedefleri (gizlilik, bütünlük, erişilebilirlik)
 - Uygulanacak standartlar (ISO 27001:2022, NIS2, OWASP, CIS Benchmarks)
 - Roller ve sorumluluklar
 - İhlal bildirim ve disiplin süreci
 - Yıllık gözden geçirme taahhüdü
- Belge şirket üst yönetimi tarafından imzalanır ve PDF olarak arşivlenir.
- Politikanın tüm çalışanlara tebliğ edildiğine dair e-posta/imza sirküleri saklanır.

Kanıt: İmzalı PDF, tebliğ kayıtları.

Adım 2: ISMS Kapsam Dokümanının ve Uygulanabilirlik Bildirgesinin (SoA) Hazırlanması

Amaç: ISO 27001 Clause 4.3 gereği ISMS kapsamının netleştirilmesi ve Annex A kontrollerinin hangilerinin uygulanacağını belgelenmesi.

Yapılacaklar:

- [docs/policies/isms-kapsam.md](#) hazırlanır:
 - Kapsam:** GD-PMS yazılım geliştirme, test, dağıtım, işletim ve bakım süreçleri. Kapsanan bileşenler: tüm apps/* ve packages/* altındaki projeler, CI/CD pipeline, Docker ortamı, TimescaleDB, Redis.
 - Kapsam dışı:** Ofis fiziksel güvenliği, kurumsal e-posta/ERP sistemleri, İK süreçleri (personel özlük dosyaları), şirket ağı (bu sistemler yazılım geliştirme ISMS'inden ayrı olarak değerlendirilecektir).

- **İlgili taraflar:** Geliştirme ekibi, müşteriler (enerji şirketleri), denetim otoriteleri, altyapı sağlayıcıları.

2. [docs/policies/uygulanabilirlik-bildirgesi.md](#) oluşturulur:

- ISO 27001:2022 Annex A'daki 93 kontrol numarası, kontrol adı, uygulanma durumu (U: Uygulanıyor / MU: Uygulanmıyor), gerekçe ve referans doküman sütunlarıyla bir tablo.
- Uygulanmayan kontroller için gerekçe yazılır (örn. A.7.x fiziksel kontroller kapsam dışı, A.5.30 ICT readiness — veri merkezi sağlayıcısı tarafından karşılanıyor).

Kanıt: Kapsam dokümanı ve SoA Excel/CSV dosyası.

Adım 3: Varlık Envanterinin Çıkarılması

Amaç: A.5.9 (Inventory of information and other associated assets) gereği tüm bilgi varlıklarının sahipleriyle birlikte kayıt altına alınması.

Yapılacaklar:

1. [docs/policies/varlik-envanteri.md](#) oluşturulur. Aşağıdaki varlık kategorileri listelenir:

Varlık	Türü	Sahibi	Kritiklik	Konum
GD-PMS Kaynak Kodu (monorepo)	Birincil bilgi varlığı	Lead Developer	Çok Yüksek	GitHub (ilterisYucel/monorepo-bun-starter)
TimescaleDB (telemetry verileri)	Birincil bilgi varlığı	Backend Lead	Çok Yüksek	Docker konteyneri
TimescaleDB (kullanıcı verileri)	Birincil bilgi varlığı	Backend Lead	Yüksek	Docker konteyneri
Redis (iş kuyruğu)	Destek varlığı	Backend Lead	Orta	Docker konteyneri
JWT Secret	Gizli varlık	Security Lead	Çok Yüksek	.env / CI secrets
CI/CD Pipeline (GitHub Actions)	Destek varlığı	DevOps Lead	Yüksek	.github/workflows/
SonarCloud Projesi	Destek varlığı	DevOps Lead	Orta	SonarCloud
Docker İmajları	Destek varlığı	DevOps Lead	Orta	Docker Hub / GHCR
SBOM Dosyaları	Destek varlığı	DevOps Lead	Orta	CI Artifacts
NPM/Bun Registry (3. parti)	Tedarik zinciri	DevOps Lead	Yüksek	npmjs.com

Varlık	Türü	Sahibi	Kritiklik	Konum
Müşteri Sözleşmeleri	Hukuki varlık	Yönetim	Yüksek	DMS
Geliştirme Ortamı (laptop)	Destek varlığı	Her geliştirici	Orta	Fiziksel
Staging Sunucusu	Destek varlığı	DevOps Lead	Orta	AWS/On-prem
Prodüksiyon Sunucusu	Destek varlığı	DevOps Lead	Çok Yüksek	Müşteri tarafı

2. Her varlık için kabul edilebilir kullanım kuralları ve koruma sınıfı belirlenir.

3. Varlık envanteri her büyük sürümde ve yılda en az bir kez güncellenir.

Kanıt: Güncel varlık envanteri dokümanı.

Adım 4: Risk Değerlendirme Metodolojisinin ve Prosedürünün Oluşturulması

Amaç: Clause 6.1.2 gereği formel bir bilgi güvenliği risk değerlendirme sürecinin tanımlanması.

Yapılacaklar:

- [docs/policies/risk-degerlendirme-proseduru.md](#) oluşturulur.
- Aşağıdaki başlıkları içerir:
 - Risk tanımlama kriterleri:** Gizlilik, bütünlük, erişilebilirlik kaybı; tehdit kaynakları (iç/dış, kasıtlı/kasıtsız)
 - Risk hesaplama formülü:** $Risk = Olasılık (1-5) \times Etki (1-5) \rightarrow Risk Seviyesi (1-25)$
 - Risk kabul kriterleri:**
 - 1-6 (Düşük): Kabul edilebilir, izlenir
 - 7-14 (Orta): Risk işleme planına alınır, 6 ay içinde kontrol uygulanır
 - 15-25 (Yüksek): Acil işleme alınır, geçici kontrol hemen uygulanır
 - Risk işleme seçenekleri:** Kaçınma, transfer, azaltma, kabul
 - Değerlendirme periyodu:** Yılda bir tam değerlendirme + her büyük mimari değişiklik öncesi
 - Sorumlular:** Risk sahibi (her varlık için), Risk Yöneticisi (Security Lead)
- Monorepo'ya özel bir tehdit kataloğu oluşturulur:
 - Bağımlılık zafiyeti (supply chain)
 - JWT token ele geçirilmesi
 - SQL injection (TimescaleDB)
 - Yetkisiz API erişimi
 - Log kurcalama (tampering)
 - Konteyner kaçışı (container escape)
 - Hizmet kesintisi (DoS/DDoS)
 - Kaynak kod sızıntısı
 - Konfigürasyon hatası (yanlış CORS, açık port)

Kanıt: Risk değerlendirme prosedürü, ilk risk değerlendirme raporu.

Adım 5: Risk İşleme Planının Oluşturulması

Amaç: Clause 6.1.3 gereği tanımlanan risklerin nasıl işleneceğinin planlanması ve kaynak tahsisinin yapılması.

Yapılacaklar:

- İlk risk değerlendirmesinde çıkan bulgular [docs/policies/risk-isleme-plani.md](#) içinde kayıt altına alınır.
- Her risk için aşağıdaki alanlar doldurulur:
 - Risk ID (örn: GDPM-R001)
 - Açıklama
 - Mevcut kontroller
 - Artık risk skoru
 - Seçilen işleme stratejisi
 - Planlanan yeni kontroller
 - Sorumlu kişi
 - Hedef tarih
 - Durum (Açık / Devam Ediyor / Kapandı / İzleniyor)
- Bu belgenin kritik bölümü: ISO 27001 kontrollerinin seçim gerekçelerini içermesi (SoA ile ilişkilendirme).

Monorepo Notu: Risk işleme planı, özellikle bu dokümanın ilerleyen adımlarındaki teknik kontrollerin neden seçildiğini gerekçelendirir. Örneğin:

- "TLS zorunluluğu → GDPM-R003'ün işlenmesi için A.8.24 seçildi"
- "Rate limiting → GDPM-R007'nin işlenmesi için A.8.22 seçildi"

Kanıt: Risk işleme planı dokümanı.

Adım 6: Bilgi Güvenliği Rollerinin ve Sorumluluklarının Tanımlanması

Amaç: A.5.2 (Information security roles and responsibilities) gereği güvenlik rollerinin netleştirilmesi.

Yapılacaklar:

- [docs/policies/guvenlik-rolleri.md](#) oluşturulur.
- Aşağıdaki roller tanımlanır:

Rol	Sorumluluklar	Atanacak Kişi
BGYS Temsilcisi (ISMS Manager)	ISMS'in kurulumu, sürdürülmesi, iç denetim koordinasyonu, yönetim gözden geçirme raporlaması	Belirlenecek
Güvenlik Mimarı (Security Lead)	Güvenlik mimarisi kararları, kod inceleme, SonarQube profil yönetimi, pentest koordinasyonu	Belirlenecek
Sistem Yöneticisi	Altyapı güvenliği, yedekleme, erişim kontrolü, Docker hardening, TLS sertifika yönetimi	Belirlenecek

Rol	Sorumluluklar	Atanacak Kişi
Geliştirici	Güvenli kodlama standartlarına uyum, SonarQube ihlallerini giderme, kod inceleme	Tüm geliştiriciler
Varlık Sahipleri	Sorumlu olduğu varlığın güvenliğinden birincil sorumluluk	Varlık envanterine göre
Üst Yönetim	Kaynak tahsisi, politika onayı, yönetim gözden geçirme	Şirket yönetimi

- Her rol için vekalet planı (yedekleme) tanımlanır.
- Roller görev tanım dokümanlarına ve iş sözleşmelerine eklenir.

Kanıt: Güvenlik rolleri dokümanı, görev tanımlarındaki güvenlik maddeleri.

Faz 2: Teknik Kontroller (NIS2'ye Ek Gereksinimler)

Bu faz, NIS2 dökümanında yer almayan veya kısmen yer alan ve ISO 27001:2022 Annex A'nın zorunlu kıldığı teknik kontrollerin uygulanmasını kapsar. Her adım ilgili Annex A kontrol numarasını referans gösterir.

Adım 7: TLS/HTTPS Zorunluluğunun Tüm Katmanlara Uygulanması

Amaç: A.8.24 (Use of cryptography) ve A.8.20 (Network security) gereği transit halindeki tüm verinin şifrelenmesi.

Mevcut Durum: Tüm backend servisler, web uygulamaları ve servisler arası iletişim düz HTTP/WS üzerinden çalışmaktadır. Prodüksiyon ortamında `VITE_API_URL=http://...` ve `VITE_WS_URL=ws://...` kullanılmaktadır. JWT token'lar ağ üzerinde açık metin olarak iletilmektedir.

Yapılacaklar:

1. Reverse Proxy (nginx) katmanında TLS:

- `apps/container-web/deployment/Dockerfile` ve diğer deployment Dockerfile'larına SSL sertifika mounting noktaları eklenir.
- nginx konfigürasyonuna TLSv1.2+ zorunluluğu, HSTS header'ı ve güçlü cipher suite'ler eklenir:

```
ssl_protocols TLSv1.2 TLSv1.3;
ssl_ciphers ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256;
ssl_prefer_server_ciphers off;
add_header Strict-Transport-Security "max-age=63072000" always;
```

- HTTP → HTTPS yönlendirmesi (301) zorunlu kılınır.
- Let's Encrypt ile otomatik sertifika yenileme certbot veya ACME istemcisi üzerinden yapılandırılır.

2. Fastify Backend Servislerde TLS:

- `web-service/src/presentation/server.ts` ve `demo-backend/src/infrastructure/api/server.ts` dosyalarına HTTPS desteği eklenir:


```
const serverOptions = process.env.HTTPS_ENABLED === "true" ? {
  https: {
    key: fs.readFileSync(process.env.TLS_KEY_PATH!),
    cert: fs.readFileSync(process.env.TLS_CERT_PATH!),
  }
} : {};
```

- `demo-backend` projesindeki mevcut `ServerConfig` tipi (`https?: { key: string; cert: string }`) etkinleştirilir.

3. Servisler Arası İletişim (Internal TLS):

- Docker Compose `deployment/docker-compose.container.yml` ve `.dev.yml` dosyalarında tüm servis URL'leri `https://` olarak güncellenir.
- Servisler arası HTTP çağrılarını için self-signed sertifika veya internal CA kullanımı değerlendirilir.
- `shared-types` içerisindeki `ssl?: boolean` (Postgres config) alanı tüm ortamlarda `true` olarak ayarlanır.

4. WebSocket (WSS) :

- `VITE_WS_URL=wss://...` olarak güncellenir.
- `web-service` ve `demo-backend` Fastify WebSocket plugin'i TLS üzerinden çalışacak şekilde yapılandırılır.

5. JWT Cookie ve Token Güvenliği:

- Refresh token'lar `Secure`, `HttpOnly`, `SameSite=Strict` flag'leri ile set edilir.
- Access token'lar için `__Host-` prefix'i kullanımı değerlendirilir.

Kanıt: SSL Labs A+ derecesi, `curl -I https://...` çıktısında HSTS header'ı, WSS bağlantı test ekran görüntüsü.

Adım 8: Security Headers Zorunluluğu

Amaç: A.8.23 (Web filtering) ve A.8.20 gereği istemci tarafı güvenlik başlıklarının zorunlu kılınması.

Mevcut Durum: Hiçbir security header (CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy) uygulanmamaktadır.

Yapılacaklar:

1. Fastify Sunuculara `@fastify/helmet` Entegrasyonu:

- `bun add @fastify/helmet` (root workspace'te)
- `web-service/src/presentation/server.ts` dosyasında `await this.app.register(helmet)` çağrısı eklenir (CORS'tan sonra, route'lardan önce).
- `demo-backend/src/infrastructure/api/server.ts` dosyasında aynı işlem uygulanır.
- Helmet varsayılan header'ları:
 - `X-Content-Type-Options: nosniff`
 - `X-Frame-Options: DENY`
 - `Strict-Transport-Security: max-age=15552000; includeSubDomains`
 - `X-XSS-Protection: 0` (modern tarayıcılarda kaldırıldı, CSP ile değiştirildi)
 - `Referrer-Policy: no-referrer`

- X-Permitted-Cross-Domain-Policies: none
- X-DNS-Prefetch-Control: off

2. Content Security Policy (CSP) Header'i:

- Helmet CSP middleware'i ile özel bir politika tanımlanır:

```
await this.app.register(helmet, {
  contentSecurityPolicy: {
    directives: {
      defaultSrc: ["'self'"],
      scriptSrc: ["'self'"],
      styleSrc: ["'self'", "'unsafe-inline'"],
      imgSrc: ["'self'", "data:"],
      connectSrc: ["'self'", "wss:", "https:"],
      fontSrc: ["'self'"],
      objectSrc: ["'none'"],
      mediaSrc: ["'self'"],
      frameSrc: ["'none'"],
    },
  },
});
```

- CSP ihlallerini toplamak için `report-uri` veya `report-to` direktifi eklenir.

3. nginx Katmanında Headers (Yedekli):

- `apps/container-web/deployment/nginx.conf` dosyasına aynı header'lar location bloklarında eklenir. Bu, reverse proxy katmanında ek bir güvenlik sağlar.

4. Test:

- Playwright E2E testlerine `security-headers.spec.ts` eklenir: her sayfada yukarıdaki header'ların varlığı doğrulanır.
- `@nis2-security` tag'ine ek olarak `@iso27001` tag'i ile işaretlenir.

Kanıt: `curl -I` çıktısı ve Playwright test sonucu.

Adım 9: Rate Limiting ve DoS Koruması

Amaç: A.8.22 (Web filtering — DoS koruması kısmı) gereği API'lerin kötüye kullanıma karşı korunması.

Mevcut Durum: Hiçbir rate limiting uygulanmamaktadır. NIS2 dökümanı Adım 8'de sadece health endpoint için rate limiting önerilmişti; ISO tüm endpoint'leri kapsar.

Yapılacaklar:

1. `bun add @fastify/rate-limit` (root workspace'te)
2. `web-service/src/presentation/server.ts` dosyasında global rate limiting uygulanır:

```
await this.app.register(rateLimit, {
  max: 100, // dakikada maksimum istek
  timeWindow: "1 minute",
  keyGenerator: (req) => {
```

```

    return req.ip; // IP bazlı sınırlama
  },
  errorHandler: (req, context) => {
    return {
      statusCode: 429,
      error: "Too Many Requests",
      message: `Rate limit exceeded. Try again in
    ${Math.ceil(context.ttl / 1000)} seconds.`
    };
  },
});

```

3. Endpoint-spesifik Rate Limitler:

- `/api/auth/login: max: 5/minute` (brute-force koruması)
- `/api/auth/register: max: 3/minute`
- `/api/nis2/health: max: 10/minute`
- `/api/commands/execute: max: 30/minute`
- `/ws/telemetry`: bağlantı başına max 1 concurrent connection

4. Redis-tabanlı Paylaşımlı Rate Limiting (Opsiyonel, Çoklu Sunucu):

- `@fastify/rate-limit` Redis store ile yapılandırılarak, birden fazla backend instance arasında paylaşımlı sayaç kullanımı.
- Mevcut Redis altyapısı bu amaçla kullanılabilir.

5. **demo-backend** sunucusuna aynı yapılandırma uygulanır.

6. **Test**: Playwright testi ile 6. login isteğinin 429 döndüğü doğrulanır.

Kanıt: Rate limit aşımında dönen 429 yanıtı ekran görüntüsü, Playwright test sonucu.

Adım 10: Docker Konteyner Güvenlik Sertleştirilmesi

Amaç: A.8.19 (Installation of software on operational systems) ve A.8.20 gereği konteyner güvenliğinin sağlanması.

Mevcut Durum: Tüm Docker konteynerleri root kullanıcısıyla çalışmaktadır. Hiçbir Docker security option (`no-new-privileges`, `read-only` roots, `cap_drop`) uygulanmamıştır. Hassas bilgiler (DB şifresi, JWT secret) docker-compose dosyalarında hard-coded olarak bulunmaktadır.

Yapılacaklar:

1. Backend Dockerfile'larına Non-Root Kullanıcı Eklenmesi:

- Her backend servis Dockerfile'ına:

```

RUN addgroup -S appgroup && adduser -S appuser -G appgroup
USER appuser

```

- Bun imajı Alpine yerine Debian/Ubuntu tabanlı ise `useradd` kullanılır.
- Uygulamanın yazma ihtiyacı olan dizinler (ör. log dizini) için `chown -R appuser:appgroup` uygulanır.

2. docker-compose.yml Güvenlik Seçenekleri:

```
services:
  web-service:
    security_opt:
      - no-new-privileges:true
    read_only: true
    tmpfs:
      - /tmp
      - /var/log
    cap_drop:
      - ALL
    cap_add:
      - NET_BIND_SERVICE # sadece port bağlamak için gerekli
```

3. İmaj Taraması:

- CI pipeline'ına `docker scout` veya `trivy image` adımı eklenir (NIS2 Adım 13'teki SBOM taramasıyla birleştirilebilir).
- Critical/HIGH CVE tespitinde build başarısız olur.

4. Docker Compose Secrets (Docker Swarm veya Compose v3+ secrets):

- Hassas değerler `docker-compose.yml` dosyasından çıkarılır, `.env.secrets` (`.gitignore`'da) dosyasına alınır.
- Alternatif olarak Docker secrets (Swarm modunda) veya HashiCorp Vault entegrasyonu değerlendirilir.

5. Image Registry Güvenliği:

- Docker imajlarının imzalanması (Docker Content Trust / `cosign`).
- Registry'de immutable tag politikası.

Kanıt: `docker inspect` çıktısı (non-root kullanıcı, security ops), Trivy image scan raporu.

Adım 11: Environment Secrets ve Konfigürasyon Yönetimi

Amaç: A.5.16 (Identity management), A.8.12 (Data leakage prevention) ve A.8.9 (Configuration management) gereği hassas konfigürasyon değerlerinin güvenli yönetimi.

Mevcut Durum:

- `JWT_SECRET=dev-secret-change-in-production` docker-compose dosyalarında hard-coded
- `POSTGRES_PASSWORD=password` docker-compose dosyalarında hard-coded
- `.env.production` dosyası repository'de olabilir (kontrol edilmeli)
- GitHub Actions secrets kullanılıyor ancak kapsamı sınırlı

Yapılacaklar:

1. .gitignore Güncellemesi:

```
.env
.env.local
```

```
.env.production
.env.secrets
*.pem
*.key
*.crt
```

Mevcut `.env.production` dosyası repository'de ise, hassas değerler temizlenir ve `.env.example` şablonu güncellenir.

2. GitHub Actions Secrets:

- `JWT_SECRET`, `DB_PASSWORD`, `REDIS_PASSWORD` CI ortamında GitHub Secrets'tan enjekte edilir.
- GitHub repo settings → Secrets and variables → Actions altına eklenir.

3. .env Dosya Şablonu:

- `packages/services/web-service/.env.example`, `packages/services/data-service/.env.example` gibi her servis için şablonlar oluşturulur.
- Şablonlarda sadece anahtar isimleri ve açıklamalar bulunur, değer alanları boştur.

4. CI Ortamında Secret Yönetimi:

- GitHub Actions workflow'larında:

```
env:
  JWT_SECRET: ${ secrets.JWT_SECRET }
  DB_PASSWORD: ${ secrets.DB_PASSWORD }
```

- Secret'lar asla `echo` veya `log`'lara yazdırılmaz.

5. Pre-commit Hook:

- `.git/hooks/pre-commit` veya Husky ile commit öncesi `.env` dosyalarının kazara eklenmesini engelleyen kontrol:

```
if git diff --cached --name-only | grep -q ".env$"; then
  echo "HATA: .env dosyası commit edilemez. Lütfen .gitignore'a ekleyin."
  exit 1
fi
```

6. SonarQube Kuralı (NIS2 Adım 3'te belirtilen):

- "Hard-coded credentials" Blocker kuralı `sonar-project.properties` exclusion list'ine `.env.example` dosyaları eklenerek rafine edilir.

Kanıt: `.gitignore` dosyası, temizlenmiş docker-compose (placeholder değerler), GitHub Secrets ekran görüntüsü.

Adım 12: Erişim Kontrol Matrisi ve RBAC Sıkılaştırması

Amaç: A.5.15 (Access control), A.5.18 (Access rights), A.8.2 (Privileged access rights), A.8.3 (Information access restriction), A.8.4 (Access to source code), A.8.5 (Secure authentication) gereği erişim kontrollerinin belgelenmesi ve sıkılaştırılması.

Mevcut Durum: `web-service/src/presentation/middleware/rbac.ts` dosyasında 4 rol (admin, teknik, guest, boss) için route bazlı RBAC mevcuttur. Ancak erişim kontrol matrisi belgelenmemiştir. Ayrıcalıklı erişim yönetimi (PAM) yoktur.

Yapılacaklar:

1. Erişim Kontrol Matrisi Dokümanı:

- `docs/policies/erisim-kontrol-matrisi.md` oluşturulur. Örnek:

Endpoint	admin	teknik	boss	guest
<code>/api/auth/login</code>	✓	✓	✓	✓
<code>/api/auth/register</code>	✓	✗	✗	✗
<code>/api/devices/</code> (list)	✓	✓	✓	✗
<code>/api/devices/{id}</code> (read)	✓	✓	✓	✗
<code>/api/devices/{id}</code> (write)	✓	✓	✗	✗
<code>/api/commands/execute</code>	✓	✓	✗	✗
<code>/api/system/config</code>	✓	✗	✗	✗
<code>/api/nis2/health</code>	✓	✗	✗	✗
<code>/ws/telemetry</code> (realtime)	✓	✓	✓	✗

2. RBAC Middleware Güncellemesi:

- Mevcut `rbac.ts` middleware'i yukarıdaki matrise göre güncellenir.
- En az ayrıcalık (least privilege) prensibiyle her route'un ihtiyacı olan minimum rol atanır.

3. Ayrıcalıklı Erişim Yönetimi (PAM):

- `admin` rolü için ek kontroller:
 - 15 dakika inactivity sonrası otomatik oturum kapatma.
 - Admin oturum açma/kapama olaylarının `TamperEvidentLogger` ile audit seviyesinde loglanması (NIS2 Adım 5-6).
- Tüm rol değişiklikleri audit log'a kaydedilir.

4. GitHub Erişim Kontrolü (A.8.4):

- Repository branch protection kuralları:
 - `main` branch'e doğrudan push yasak.
 - Tüm PR'lar en az 1 reviewer gerektirir.
 - SonarQube Quality Gate ve CI testleri geçmeden merge edilemez.
- Repository rolleri: Admin, Maintainer, Write, Read şeklinde ayrıştırılır.

5. Parola Politikası:

- Minimum 12 karakter, en az 1 büyük harf, 1 küçük harf, 1 rakam, 1 özel karakter.
- Son 5 parola tekrar kullanılamaz.

- 90 günde bir parola değişimi (teknik personel için).
- Başarısız giriş denemesi: 5 deneme sonrası 15 dakika hesap kilitleme.

Kanıt: Erişim kontrol matrisi dokümanı, GitHub branch protection ekran görüntüsü.

Adım 13: Yedekleme ve Geri Dönme Otomasyonu

Amaç: A.8.13 (Information backup) gereği kritik verilerin düzenli, testli ve şifrelenmiş yedeklerinin alınması.

Mevcut Durum: Otomatik yedekleme mevcut değildir.

Yapılacaklar:

1. Yedekleme Stratejisi Dokümanı:

- `docs/policies/yedekleme-stratejisi.md` oluşturulur.
- **Kapsam:** TimescaleDB (tüm veritabanları), Redis (RDB dump), konfigürasyon dosyaları, Docker Compose dosyaları.
- **Yedekleme Sıklığı:**
 - TimescaleDB: Her gece full dump + sürekli WAL archiving
 - Redis: Her saat RDB snapshot
 - Konfigürasyon: Her deploy öncesi
- **Saklama Süresi:** Günlük 7 gün, haftalık 4 hafta, aylık 12 ay
- **Yedekleme Konumu:** En az iki fiziksel olarak ayrı konum (örn. primary storage + S3/Blob)

2. Otomasyon Scripti:

- `scripts/backup.sh` oluşturulur:

```
#!/bin/bash
TIMESTAMP=$(date +%Y%m%d_%H%M%S)
BACKUP_DIR="/backups/$TIMESTAMP"

# TimescaleDB dump
docker exec timescaledb pg_dumpall -U postgres | gzip >
"$BACKUP_DIR/timescale.sql.gz"

# Redis RDB copy
docker cp redis:/data/dump.rdb "$BACKUP_DIR/redis.rdb"

# Encrypt backup
gpg --encrypt --recipient security@gdpms.com
"$BACKUP_DIR/timescale.sql.gz"

# Upload to remote
aws s3 cp "$BACKUP_DIR" "s3://gd-pms-backups/$TIMESTAMP/" --
recursive
```

3. Cron Job:

- Host sunucuda veya Kubernetes CronJob ile schedule edilir.
- Yedekleme başarı/başarısızlık durumu e-posta/uyarı ile bildirilir.

4. Geri Dönme Testi:

- 3 ayda bir, staging ortamında yedekten geri dönme tatbikatı yapılır.
- Test sonucu `docs/policies/yedekleme-test-kayitlari.md` dosyasına işlenir.

5. Yedekleme Güvenliği:

- Yedekler AES-256 ile şifrelenir (GPG veya benzeri).
- Yedekleme konumlarına erişim sadece Sistem Yöneticisi rolüne sınırlandırılır.
- Yedeklerden geri dönme işlemi `admin` rolü onayı gerektirir ve audit log'a kaydedilir.

Kanıt: Yedekleme scripti, cron job konfigürasyonu, başarılı geri dönme test raporu.

Adım 14: Ağ Segmentasyonu ve İç Ağ Güvenliği

Amaç: A.8.20 (Networks security) ve A.8.21 (Security of network services) gereği servisler arası ağ izolasyonu.

Mevcut Durum: Docker Compose varsayılan bridge ağı kullanılmaktadır. Servisler arası ağ segmentasyonu yoktur.

Yapılacaklar:

1. Docker Compose Ağ Segmentasyonu:

- `deployment/docker-compose.container.yml` dosyasında özel ağlar tanımlanır:

```
networks:
  frontend:
    driver: bridge
  backend:
    driver: bridge
    internal: true      # Dış dünyaya erişimi yok
  database:
    driver: bridge
    internal: true
```

- Servisler sadece ihtiyaç duydukları ağlara bağlanır:

- `nginx` → `frontend` + `backend`
- `web-service` → `backend` + `database`
- `data-service` → `backend` + `database`
- `device-service` → `backend`
- `timescaledb` → `database`
- `redis` → `backend`

2. Port Exposure:

- Sadece `nginx` port 443 dış dünyaya expose edilir.
- `timescaledb:5432`, `redis:6379` portları host'a expose edilmez (`ports` tanımından çıkarılır).

3. Servisler Arası Güvenlik Duvarı (Opsiyonel):

- Container seviyesinde iptables kuralları veya `ufw` ile sadece izin verilen portlar arası trafik.

4. API Gateway (Gelecek Aşama):

- Tüm backend servis isteklerinin tek bir noktadan (web-service veya ayrı bir API gateway) geçmesi.
- Doğrudan data-service veya device-service'e erişim engellenir.

Kanıt: `docker network inspect` çıktısı, port tarama test sonucu (sadece 443 açık).

Adım 15: SonarQube — ISO 27001 için Ek Kalite Kuralları

Amaç: NIS2 Adım 1-4'teki SonarQube yapılandırmasına ek olarak ISO 27001:2022'nin gerektirdiği kontrollere özel kuralların eklenmesi.

Yapılacaklar:

1. Mevcut "NIS2 Compliance - TypeScript" profiline ek kurallar:

- `crypto.getRandomValues` yerine `Math.random()` kullanan kodlar: Blocker
- SQL injection'a açık string concatenation: Blocker (custom ESLint kuralı `require-parameterized-query` SonarQube'e taşınır)
- Şifrelenmemiş cookie set eden kodlar: Critical
- `eval()`, `new Function()`, `setTimeout(string)` kullanımı: Blocker
- DOM'dan doğrudan HTML enjeksiyonu (`innerHTML`, `document.write`): Critical
- `fs.readFileSync` ile dosya yolu kullanıcı girdisi içeren kodlar: Critical (path traversal)

2. Yeni Özel SonarQube Kuralı — `@iso27001-no-http-url`:

- HTTP URL'leri (prod ortamında) hard-coded olarak tespit eden kural.
- Şiddet: Critical.
- Hata mesajı: "ISO 27001 A.8.24: Tüm iletişim HTTPS/WSS üzerinden olmalıdır. http:// veya ws:// kullanmayın."
- İstisna: `localhost` geliştirme ortamı için `// skip-iso-check` yorum satırı.

3. Quality Gate Güncellemesi:

- NIS2 Adım 4'teki "NIS2 Gate - GD-PMS" kapısına ISO 27001 ek koşulları:
 - `Code Smells` > 0 ise: Başarısız (yeni ek)
 - `Duplicated Lines (%)` > %3 ise: Başarısız (yeni ek)

4. Monorepo'da proje bazlı SonarQube:

- Her `apps/*` ve `packages/*` projesi için ayrı SonarQube projesi.
- Bu sayede hangi projenin Quality Gate'i geçemediği net görülür.

Kanıt: Genişletilmiş Quality Profile ekran görüntüsü, `@iso27001-no-http-url` kural tanımı.

Adım 16: SBOM ve Bağımlılık Taraması

Amaç: NIS2 Adım 13 ile aynı teknik altyapıyı kullanarak A.8.8, A.8.9 ve A.5.19 (supplier security) kontrollerinin ISO kanıtlarının üretilmesi.

Yapılacaklar:

NIS2 Adım 13'te planlanan adımların aynısı uygulanır:

1. `@cyclonedx/bom` ile her build'de `sbom.json` üretimi.
2. Trivy ile CVE taraması.

3. Critical CVE durumunda build'in başarısız olması.

ISO 27001'e Özel Ek Gereksinimler: 4. Tedarikçi Risk Değerlendirmesi:

- Her bağımlılık (npm package) bir tedarikçi olarak değerlendirilir.
- Aşağıdaki kriterlere göre kritik bağımlılıklar listesi çıkarılır:
 - Kimlik doğrulama/şifreleme ile ilgili paketler (`jose`, `bcrypt`, vb.)
 - Veritabanı sürücüler (`pg`)
 - Framework'ler (`fastify`, `react`)
- Bu paketlerin bakım durumu, son güncelleme tarihi, CVE geçmişi periyodik olarak kontrol edilir.

5. Lisans Uyumluluğu (A.5.32 — Intellectual property rights):

- Trivy veya `license-checker` ile tüm bağımlılıkların lisansları taranır.
- Copyleft lisanslar (GPL, AGPL) tespit edilir ve hukuki risk değerlendirilir.

6. Bun Lockfile Integrity:

- `bun.lock` dosyasının commit edildiği ve CI'da `bun install --frozen-lockfile` kullanıldığı doğrulanır.
- Bu, tedarik zinciri bütünlüğünün (supply chain integrity) kanıtıdır.

Kanıt: SBOM dosyası, Trivy raporu, bağımlılık risk değerlendirme tablosu, lisans tarama raporu.

Adım 17: TamperEvidentLogger — ISO 27001 Ek Gereksinimleri

Amaç: NIS2 Adım 5-8'deki TamperEvidentLogger altyapısına ISO 27001'in eklediği loglama gerekliliklerinin entegre edilmesi.

ISO 27001'in NIS2'ye Ek Olarak İstedikleri:

NIS2 Adım 5-8'de `packages/core/src/lib/logger/tamper-evident-logger.ts` oluşturulup backend servislere entegre edilecektir. Bu altyapıya ISO için aşağıdaki ek özellikler eklenir:

Gereksinim	ISO Kontrolü	Durum
Hash zincirli tamper-evident loglama	A.8.15, A.8.16	✓ NIS2 Adım 5-7
JSON formatlı log çıktısı (SIEM uyumlu)	A.8.15	✓ NIS2 Adım 5
Admin işlemleri audit seviyesinde loglama	A.8.15, A.8.2	✓ NIS2 Adım 5
Health check endpoint	A.8.16	✓ NIS2 Adım 8
Saat senkronizasyonu (NTP) kaydı	A.8.17 Clock synchronization	✗ Eksik
Log saklama süresi politikası	A.8.15	✗ Eksik
Log erişim kontrolü	A.8.15, A.8.3	✗ Eksik
Kapasite izleme (disk, bellek, CPU)	A.8.16	✗ Eksik
Log rotasyon ve arşivleme	A.8.15	✗ Eksik

Yapılacaklar (ISO'ya Özel Ekler):

1. Saat Senkronizasyonu (A.8.17):

- Docker Compose'da tüm servislerin aynı timezone'da çalışması (TZ=Europe/Istanbul).
- Host sunucuda NTP servisi (chronyd veya ntpd) aktif.
- Loglara NTP offset bilgisi eklenir: "ntp_offset_ms": 0.42.

2. Log Saklama ve Rotasyon Politikası:

- docs/policies/log-saklama-politikasi.md oluşturulur.
- Saklama süreleri: Audit log 3 yıl, sistem log 1 yıl, debug log 30 gün.
- Log rotasyonu: Günlük rotasyon, logrotate veya uygulama içi mekanizma.

3. Log Erişim Kontrolü:

- Log dizinlerine sadece admin rolü ve Sistem Yöneticisi erişebilir.
- Log dosyaları 640 permission ile oluşturulur.

4. Kapasite İzleme:

- Health check endpoint'ine ek alanlar:

```
{
  "status": "healthy",
  "capacity": {
    "disk_used_percent": 45,
    "memory_used_percent": 62,
    "cpu_percent": 23
  }
}
```

- Disk %80 aşınca uyarı, %90 aşınca critical alert.

Kanıt: NTP konfigürasyonu, log saklama politikası dokümanı, genişletilmiş health check yanıtı.

Faz 3: Operasyonel Kontroller

Bu faz, ISO 27001'in operasyonel süreç gerekliliklerini kapsar. Geliştirme faaliyeti azdır; dokümantasyon ve süreç tanımları ağırlıklıdır.

Adım 18: Olay Müdahale Prosedürünün Oluşturulması

Amaç: A.5.24 (Information security incident management planning and preparation) ve A.5.25-A.5.28 gereği güvenlik olaylarına müdahale sürecinin tanımlanması.

Yapılacaklar:

1. docs/policies/olay-mudahale-proseduru.md oluşturulur. Aşağıdaki başlıkları içerir:
 - **Olay tanımı ve sınıflandırması:**
 - **P1 (Kritik):** Prodüksiyon kesintisi, veri sızıntısı, yetkisiz admin erişimi
 - **P2 (Yüksek):** Servis kısmi kesintisi, başarılı phishing girişi
 - **P3 (Orta):** SonarQube Blocker ihlali, başarısız brute-force denemesi
 - **P4 (Düşük):** Politika ihlali, minor config hatası
 - **Eskalasyon zinciri:** Tespit eden → Security Lead → BGYS Temsilcisi → Üst Yönetim

- **Müdahale adımları:** Tespit → Sınıflandırma → İzolasyon → Analiz → İyileştirme → Raporlama → Ders Çıkarma
- **İletişim planı:** Kim, kime, ne zaman, hangi kanaldan
- **Dış bildirim yükümlülükleri:** Müşteriye bildirim süresi (P1: 4 saat, P2: 24 saat), KVKK/veri koruma otoritesine bildirim (72 saat)

2. Olay Kayıt ve Takip Aracı:

- GitHub Issues veya ayrı bir ITSM aracı ile olay takibi.
- Her olay için [olay-kaydi-sablonu.md](#) şablonu.

3. Yıllık Masaüstü Tatbikatı:

- Senede bir, tüm ekibin katılımıyla bir senaryo (örn: "TimescaleDB fidye yazılımı ile şifrelendi") masa başında simüle edilir.
- Tatbikat raporu [docs/policies/tatbikat-kayitlari/](#) altında arşivlenir.

Kanıt: Olay müdahale prosedürü, tatbikat raporu, doldurulmuş olay kaydı örneği.

Adım 19: İş Sürekliliği Planının (BCP) Oluşturulması

Amaç: A.5.29 (Information security during disruption) ve A.5.30 (ICT readiness for business continuity) gereği hizmet kesintisi durumunda iş sürekliliğinin sağlanması.

Yapılacaklar:

1. [docs/policies/is-surekliligi-plani.md](#) oluşturulur:

- **Kritik servisler ve RTO/RPO:**

Servis	RTO (Recovery Time)	RPO (Recovery Point)
web-service	1 saat	5 dakika
data-service	4 saat	1 saat
device-service	8 saat	1 saat
TimescaleDB	2 saat	1 saat
Redis (BullMQ)	1 saat	0 (yeniden kuyruğa alınabilir)
Web Frontend (nginx)	30 dakika	N/A (statik)
Desktop App	N/A (istemci tarafı)	N/A

- **Kesinti senaryoları:**

- Veritabanı sunucusu çökmesi
- Disk dolması
- Ağ kesintisi
- Docker host arızası
- Veri merkezi kesintisi
- Fidye yazılımı saldırısı

- **Her senaryo için recovery playbook'u:**

- Ön koşullar (yedeklerin erişilebilir olması, yedek sunucu)
- Adım adım geri dönme prosedürü
- Doğrulama adımları (health check, duman testi)

- Rollback planı

2. Yedekli Altyapı (Opsiyonel, Maliyetli):

- TimescaleDB streaming replication (primary-standby)
- Redis Sentinel veya Cluster
- Load balancer önünde en az 2 web-service instance

3. Yıllık BCP Tatbikatı:

- Staging ortamında planlı kesinti simülasyonu.
- RTO hedeflerinin karşılanıp karşılanmadığı ölçülür.

Kanıt: BCP dokümanı, tatbikat raporu, RTO ölçüm sonuçları.

Adım 20: Tedarikçi Güvenlik Değerlendirme Süreci

Amaç: A.5.19 (Information security in supplier relationships), A.5.20, A.5.21, A.5.22 gereği tedarikçilerin güvenlik değerlendirmesi.

Yapılacaklar:

1. [docs/policies/tedarikci-guvenlik-degerlendirme.md](#) oluşturulur.

2. Tedarikçi Envanteri:

Tedarikçi	Kategori	Kritiklik	Değerlendirme
GitHub (kod barındırma)	Altyapı	Çok Yüksek	SOC2 raporu talep edildi
SonarCloud (kod analizi)	Araç	Orta	SOC2 Tip II mevcut
npmjs.com / Bun Registry	Tedarik zinciri	Yüksek	Sürekli CVE izleme
Docker Hub / GHCR	Altyapı	Orta	-
AWS/On-prem sağlayıcı	Altyapı	Çok Yüksek	ISO 27001 / SOC2 zorunlu
Harici pentest firması	Hizmet	Yüksek	CREST/CHECK akreditasyonu
Müşteri (enerji şirketi)	Müşteri	Düşük	Sözleşmede güvenlik maddeleri

3. Tedarikçi Sözleşme Maddeleri (A.5.20):

- Tüm yeni tedarikçi sözleşmelerine aşağıdaki maddeler eklenir:
 - Bilgi güvenliği olay bildirim süresi (48 saat)
 - Alt işleyici kullanımı için onay zorunluluğu
 - İş bitiminde veri imha taahhüdü
 - Denetim hakkı (denetim yapma veya bağımsız denetim raporu talep etme)

4. Yıllık Tedarikçi Gözden Geçirme:

- Kritik tedarikçiler yılda bir yeniden değerlendirilir.
- Değerlendirme formu: [docs/policies/tedarikci-degerlendirme-formu.md](#)

Kanıt: Tedarikçi envanteri, değerlendirme formları, sözleşme örnekleri (hassas kısımlar maskeli).

Adım 21: Personel Farkındalık Eğitim Programı

Amaç: A.6.3 (Information security awareness, education and training) gereği tüm personelin düzenli güvenlik eğitimi alması.

Yapılacaklar:

1. docs/policies/farkindalik-egitim-plani.md oluşturulur:

- **İşe giriş eğitimi:** İlk hafta içinde, 2 saat. İçerik: Bilgi güvenliği politikası, parola politikası, temiz masa politikası, sosyal mühendislik farkındalığı.
- **Yıllık zorunlu eğitim:** Tüm personel için 1 saat. İçerik: Güncel tehditler, phishing simülasyonu, olay bildirim prosedürü.
- **Role özel eğitimler:**
 - Geliştiriciler: Yılda 1 kez OWASP Top 10 farkındalığı, güvenli kodlama (NIS2 Adım 16 — SSDF).
 - Sistem Yöneticisi: Docker güvenliği, ağ güvenliği, yedekleme.
 - Yöneticiler: ISMS farkındalığı, risk yönetimi, yasal yükümlülükler.

2. Eğitim Kayıtları:

- Her eğitim için katılım listesi ve sınav sonucu (min %70 başarı) arşivlenir.

3. Phishing Simülasyonu:

- 3 ayda bir, tüm personele sahte phishing e-postası gönderilir.
- Tıklama oranı ölçülür ve ek eğitim planlanır.

Kanıt: Eğitim planı, katılım listeleri, phishing simülasyon raporu.

Adım 22: Gizlilik Sözleşmeleri ve İşe Alım Kontrolleri

Amaç: A.6.1 (Screening), A.6.2 (Terms and conditions of employment), A.6.5 (Responsibilities after termination), A.6.6 (Confidentiality or non-disclosure agreements) gereği personel güvenliği.

Yapılacaklar:

1. İşe Alım Kontrol Listesi:

- Referans kontrolü (teknik personel için)
- Adli sicil kaydı kontrolü (hassas müşteri verilerine erişecek roller için)
- İmzalanan belgeler: İş sözleşmesi, gizlilik sözleşmesi (NDA), bilgi güvenliği politikası tebliğ-tebellüğ belgesi

2. Gizlilik Sözleşmesi (NDA):

- docs/policies/gizlilik-sozlesmesi-taslagi.md — hukukçu onayından geçirilir.
- İçerik: Proje süresince ve işten ayrıldıktan sonra 3 yıl süreyle gizlilik yükümlülüğü.

3. İşten Ayrılma Prosedürü:

- Erişim haklarının iptali (ilk 24 saat içinde):
 - GitHub repo erişimi
 - Sunucu/SSH erişimi
 - Veritabanı kullanıcısı
 - E-posta ve iletişim araçları

- Şirket cihazlarının iadesi
- Gizlilik yükümlülüğünün devam ettiğine dair yazılı teyit

Kanıt: Kontrol listeleri, NDA şablonu, erişim iptal kayıtları.

Adım 23: Fiziksel Güvenlik Kontrolleri — Kapsam Notu

Amaç: Annex A.7 (Physical controls) kontrollerinin ISMS kapsamındaki durumunun belgelenmesi.

ISO 27001:2022 Annex A.7 — 14 Fiziksel Kontrol:

Kontrol	Açıklama	Durum
A.7.1	Physical security perimeters	Kapsam Dışı — Ofis/sunucu odası bu ISMS kapsamında değil
A.7.2	Physical entry controls	Kapsam Dışı
A.7.3	Securing offices, rooms and facilities	Kapsam Dışı
A.7.4	Physical security monitoring	Kapsam Dışı
A.7.5	Protecting against physical and environmental threats	Kapsam Dışı
A.7.6	Working in secure areas	Kapsam Dışı
A.7.7	Clear desk and clear screen	⚠ Kısım — Geliştiricilere temiz masa/ekran politikası tebliğ edilir
A.7.8	Equipment siting and protection	Kapsam Dışı
A.7.9	Security of assets off-premises	⚠ Kısım — Şirket laptop'ları disk şifreleme ve uzaktan silme
A.7.10	Storage media	Kapsam Dışı
A.7.11	Supporting utilities	Kapsam Dışı
A.7.12	Cabling security	Kapsam Dışı
A.7.13	Equipment maintenance	Kapsam Dışı
A.7.14	Secure disposal or reuse of equipment	⚠ Kısım — Emekli edilen laptop/sunucu diskleri secure wipe

Aksiyonlar:

- A.7.7 (Temiz Masa/Temiz Ekran) — Farkındalık eğitimine eklenir, ofislere hatırlatma posterleri.
- A.7.9 (Saha Dışı Varlıklar) — Tüm şirket laptop'larına tam disk şifreleme (BitLocker/LUKS) zorunluluğu. Uzaktan silme (MDM) çözümü değerlendirilir.
- A.7.14 (Güvenli İmha) — Emekli edilen depolama ortamları için **shred** veya fiziksel imha prosedürü.

Bu kontrollerin tamamı SoA'da "uygulanmıyor — kapsam dışı" olarak işaretlenir, gerekçeleri yazılır.

Kanıt: SoA dokümanındaki gerekçelendirmeler, temiz masa politikası tebliğ kaydı, disk şifreleme kontrolü.

Faz 4: İzleme, Ölçme, İç Denetim ve İyileştirme

Adım 24: İç Denetim Programının Oluşturulması

Amaç: Clause 9.2 (Internal audit) gereği ISMS'in düzenli olarak iç denetimden geçirilmesi.

Yapılacaklar:

1. [docs/policies/ic-denetim-proseduru.md](#) oluşturulur:

- **Denetim sıklığı:** Yılda en az 1 tam denetim. Kritik alanlar için 6 ayda bir ara denetim.
- **Denetçi yetkinliği:** İç denetçiler ISO 27001 İç Denetçi eğitimi almış olmalı. Kendi çalışma alanlarını denetleyemezler (bağımsızlık şartı).
- **Denetim kapsamı:** Tüm Annex A kontrolleri, politika uyumluluğu, yasal gereklilikler.
- **Denetim raporu formatı:** Bulgu, uygunsuzluk sınıfı (major/minor/observation), referans kontrol, öneri, sorumlu, hedef tarih.

2. İç Denetim Takvimi:

- Yıllık denetim planı oluşturulur. Örnek:

Ay	Denetim Konusu	Denetçi
Mart	A.8 Teknolojik kontroller (TLS, headers, rate limit, Docker)	BGYS Temsilcisi
Haziran	A.5 Organizasyonel kontroller (politikalar, tedarikçi)	Dış danışman
Eylül	A.6 İnsan kontrolleri (eğitim, NDA, işe alım)	İK + BGYS Temsilcisi
Aralık	Tam ISMS denetimi (belgelendirme öncesi)	Dış danışman

3. Düzeltici Faaliyet Takibi:

- Denetim bulguları için [docs/policies/duzeltici-faaliyet-takip.md](#) oluşturulur.
- Her bulgu için kök neden analizi ve kapatma kanıtı.

Kanıt: İç denetim prosedürü, denetim takvimi, örnek denetim raporu, düzeltici faaliyet kaydı.

Adım 25: Yönetim Gözden Geçirme Toplantısı

Amaç: Clause 9.3 (Management review) gereği üst yönetimin ISMS'i periyodik olarak gözden geçirmesi.

Yapılacaklar:

1. [docs/policies/yonetim-gozden-gecirme-proseduru.md](#) oluşturulur.

2. **Toplantı Sıklığı:** Yılda en az 1 kez (sertifikasyon denetimi öncesi).

3. **Toplantı Gündemi (ISO 27001 Clause 9.3.2):**

- Önceki toplantı kararlarının durumu
- ISMS ile ilgili iç ve dış değişiklikler
- Bilgi güvenliği performans göstergeleri:

- SonarQube Quality Gate geçme oranı (%)
- Açık Critical/Blocker issue sayısı
- Kapatılan olay sayısı ve ortalama çözüm süresi
- İç denetim bulguları (açık/kapalı)
- Eğitim tamamlanma oranı
- Tedarikçi değerlendirme sonuçları
- Kaynak ihtiyacı değerlendirmesi
- Sürekli iyileştirme fırsatları

4. Toplantı Çıktısı:

- Kararlar, aksiyon maddeleri ve sorumluların yer aldığı imzalı toplantı tutanağı.
- [docs/policies/ygg-tutanaklari/](#) altında arşivlenir.

Kanıt: Toplantı gündemi, imzalı tutanak, aksiyon takip tablosu.

Adım 26: Sürekli İyileştirme ve Düzeltici Faaliyet Prosedürü

Amaç: Clause 10.1 (Continual improvement) ve 10.2 (Nonconformity and corrective action) gereği uygunsuzlukların yönetimi.

Yapılacaklar:

1. [docs/policies/duzeltici-faaliyet-proseduru.md](#) oluşturulur.

2. Uygunsuzluk Kaynakları:

- İç denetim bulguları
- Harici denetim bulguları
- Güvenlik olayları (post-mortem)
- Müşteri şikayetleri
- Politika ihlalleri

3. Süreç Akışı:

- Uygunsuzluk tespiti → Kök neden analizi (5 Whys / Balık Kılçığı) → Düzeltici faaliyet planı → Uygulama → Etkinlik kontrolü → Kapatma

4. Sürekli İyileştirme Örnekleri:

- Her büyük olay sonrası "lessons learned" oturumu
- Her sprint retrospective'te güvenlik maddesi
- Yıllık ISMS olgunluk değerlendirmesi (CMMI veya ISO 27004)

Kanıt: Düzeltici faaliyet prosedürü, doldurulmuş düzeltici faaliyet formu örnekleri.

Faz 5: Sertifikasyon Yol Haritası

Adım 27: Sertifikasyon Kuruluşu Seçimi

Amaç: Akredite bir belgelendirme kuruluşundan ISO/IEC 27001:2022 sertifikası alınması.

ISO 27001 Sertifikasyon Süreci (NIS2'den Farkı):

NIS2'de resmi bir sertifikasyon programı yoktur, uygunluk değerlendirmesi yapılır. ISO 27001 ise **akredite belgelendirme kuruluşları** tarafından verilen formal bir sertifikadır. Sertifika uluslararası geçerliliğe sahiptir

ve IAF (International Accreditation Forum) üyesi akreditasyon kurumları tarafından tanınır.

Kuruluş Tipleri ve Maliyet Karşılaştırması:

Kuruluş Tipi	Örnekler	Tahmini Maliyet (3 yıl)	Avantaj	Dezavantaj
Büyük Dörtlü (Big Four)	Deloitte, PwC, EY, KPMG	€30.000 – €80.000	En yüksek prestij, global tanınırlık	Yüksek maliyet, bürokratik süreç
Uluslararası Sertifikasyon Kuruluşları	BSI, TÜV, SGS, Bureau Veritas	€15.000 – €40.000	Geniş akreditasyon kapsamı, yaygın tanınırlık	Orta maliyet
Butik/Uzman Belgelendirme	NCC Group, LRQA, yerel akredite kuruluşlar	€8.000 – €20.000	Düşük maliyet, esnek süreç	Bazı müşteriler tarafından daha az tanınabilir
GRC Platformu + Harici Denetçi	Vanta + partner auditor, Drata + partner	\$10.000 – \$25.000/yıl (platform + denetim)	Sürekli uyumluluk izleme, otomasyon	Platform bağımlılığı

Seçim Kriterleri:

1. IAF üyesi bir akreditasyon kurumu tarafından akredite olması (TÜRKAK, UKAS, DAKKS, vb.)
2. Enerji/BT sektöründe deneyim
3. Türkçe/İngilizce denetim yapabilmesi
4. Referans müşterileri

Öneri: Bütçeye bağlı olarak BSI veya TÜV gibi uluslararası tanınırlığı yüksek bir kuruluş tercih edilmelidir. Enerji sektörü müşterileri genellikle bu kuruluşların sertifikalarını tanımaktadır.

Adım 28: Sertifikasyon Denetim Takvimi ve Süreci

Amaç: Belgelendirme sürecinin planlanması.

ISO 27001 Belgelendirme Döngüsü (3 Yıl):

Aşama	Zamanlama	Faaliyet	Süre
Hazırlık	0-6 ay	ISMS dokümantasyonu, teknik kontrollerin uygulanması, iç denetim, yönetim gözden geçirme	-
Stage 1 Denetimi	6. ay	Dokümantasyon incelemesi (politikalar, SoA, risk değerlendirmesi, prosedürler). Denetçi ISMS'in kağıt üzerinde uygunluğunu kontrol eder.	1-3 gün
Stage 1 Bulgularının Kapatılması	6-8. ay	Stage 1'de tespit edilen eksiklerin giderilmesi	1-2 ay

Aşama	Zamanlama	Faaliyet	Süre
Stage 2 Denetimi	8-9. ay	Saha denetimi. Tüm kontrollerin uygulandığının kanıt kontrolü. Çalışan görüşmeleri.	2-5 gün
Sertifika Verilmesi	9. ay	Stage 2 başarılı ise 3 yıl geçerli sertifika düzenlenir	-
Gözetim 1 (Surveillance)	18. ay	Kısmi denetim (ISMS'in sürdürüldüğünün kontrolü)	1-2 gün
Gözetim 2 (Surveillance)	30. ay	Kısmi denetim	1-2 gün
Yeniden Belgelendirme (Re-certification)	36. ay	Tam denetim (Stage 2 benzeri)	2-5 gün

Kanıt Paketi Hazırlığı:

Stage 2 denetiminde denetçiye sunulacak kanıtların önceden hazırlanması:

Kanıt Kategorisi	Örnek Kanıtlar
Politika ve Prosedürler	İmzalı Bilgi Güvenliği Politikası, SoA, tüm prosedür dokümanları
Risk Yönetimi	Risk değerlendirme raporu, risk işleme planı, risk kabul formları
İK Güvenliği	İmzalı NDA'lar, eğitim katılım listeleri, işe alım kontrol listeleri
Erişim Kontrolü	Erişim kontrol matrisi, kullanıcı erişim inceleme kayıtları, admin aktivite logları
Kriptografi	TLS sertifikaları, SSL Labs raporu, anahtar yönetim prosedürü
Yazılım Güvenliği	SonarQube Quality Gate raporları, CI/CD logları, kod inceleme kayıtları
Tedarikçi	Tedarikçi değerlendirme formları, sözleşme güvenlik maddeleri
Olay Yönetimi	Olay kayıtları, post-mortem raporları, tatbikat raporları
İş Sürekliliği	BCP dokümanı, yedekleme test raporları, BCP tatbikat raporu
İç Denetim	İç denetim programı, denetim raporları, düzeltici faaliyet kayıtları
Yönetim Gözden Geçirme	YGG toplantı tutanakları, aksiyon takip tablosu
Teknik Kanıtlar	<code>curl -I</code> çıktıları (security headers), rate limit test sonucu, Docker inspect çıktısı, SBOM ve Trivy raporu

Özet Kontrol Listesi

#	Adım	Kategori	Konum
1	Bilgi Güvenliği Politikası	ISMS	docs/policies/

#	Adım	Kategori	Konum
2	ISMS Kapsamı ve SoA	ISMS	docs/policies/
3	Varlık Envanteri	ISMS	docs/policies/
4	Risk Değerlendirme Prosedürü	ISMS	docs/policies/
5	Risk İşleme Planı	ISMS	docs/policies/
6	Güvenlik Roller	ISMS	docs/policies/
7	TLS/HTTPS Zorunluluğu	Teknik	Fastify + nginx + Docker Compose
8	Security Headers (Helmet, CSP)	Teknik	web-service, demo-backend, nginx
9	Rate Limiting	Teknik	web-service, demo-backend
10	Docker Hardening	Teknik	Tüm Dockerfile ve docker-compose
11	Environment Secrets Yönetimi	Teknik	.gitignore, CI, pre-commit hook
12	Erişim Kontrol Matrisi ve PAM	Teknik	rbac.ts + docs/policies/
13	Yedekleme Otomasyonu	Teknik	scripts/backup.sh
14	Ağ Segmentasyonu	Teknik	docker-compose.yml
15	SonarQube ISO Ek Kuralları	Kod Kalitesi	SonarQube UI + sonar-project.properties
16	SBOM ve Tedarikçi Risk (ISO Ekleri)	Tedarik Zinciri	CI pipeline
17	TamperEvidentLogger ISO Ekleri	Loglama	packages/core/src/lib/logger/
18	Olay Müdahale Prosedürü	Operasyonel	docs/policies/
19	İş Sürekliliği Planı (BCP)	Operasyonel	docs/policies/
20	Tedarikçi Güvenlik Değerlendirme	Operasyonel	docs/policies/
21	Farkındalık Eğitim Programı	Operasyonel	docs/policies/ + eğitim kayıtları
22	Gizlilik Sözleşmeleri ve İşe Alım	Operasyonel	docs/policies/ + İK
23	Fiziksel Güvenlik (Kapsam Notu)	Fiziksel	docs/policies/ + SoA
24	İç Denetim Programı	İzleme	docs/policies/
25	Yönetim Gözden Geçirme	İzleme	docs/policies/
26	Düzeltilici Faaliyet Prosedürü	İyileştirme	docs/policies/
27	Sertifikasyon Kuruluşu Seçimi	Sertifikasyon	Dış kaynak
28	Sertifikasyon Denetim Süreci	Sertifikasyon	Takvim + kanıt paketi

Ek A: Maliyet Kalemleri (Geliştirme Hariç)

Aşağıdaki tüm rakamlar tahmini olup, 2026 piyasa koşullarına göre güncellenmelidir. Geliştirme işçilik maliyetleri bu tabloya dahil değildir.

A.1 Tek Seferlik Maliyetler (Başlangıç)

Kalem	Aralık (EUR)	Aralık (TL)	Açıklama
Stage 1 Denetimi (Dokümantasyon)	€2.000 – €5.000	₺80.000 – ₺200.000	Belgelendirme kuruluşu günlük ücreti (1-2 gün)
Stage 2 Denetimi (Saha)	€4.000 – €12.000	₺160.000 – ₺480.000	Belgelendirme kuruluşu günlük ücreti (3-5 gün)
Danışmanlık — Gap Analysis	€3.000 – €8.000	₺120.000 – ₺320.000	Mevcut durum analizi ve eksik raporu
Danışmanlık — ISMS Kurulum Desteği	€8.000 – €25.000	₺320.000 – ₺1.000.000	Politika yazımı, risk değerlendirme, SoA hazırlığı
Danışmanlık — Pre-Audit Check	€2.000 – €5.000	₺80.000 – ₺200.000	Stage 2 öncesi hazırlık denetimi
İç Denetçi Eğitimi (1 kişi)	€1.000 – €2.000	₺40.000 – ₺80.000	ISO 27001 Internal Auditor sertifikası
Lead Implementer Eğitimi (1 kişi)	€1.500 – €3.000	₺60.000 – ₺120.000	ISO 27001 Lead Implementer sertifikası
Başlangıç Toplamı	€21.500 – €60.000	₺860.000 – ₺2.400.000	

A.2 Yıllık Yenilenen Maliyetler

Kalem	Aralık (EUR)	Aralık (TL)	Açıklama
Gözetim Denetimi (Surveillance Audit)	€3.000 – €6.000	₺120.000 – ₺240.000	Yılda 1 kez (Sertifika yılı 2 ve 3)
Harici Pentest (CREST/CHECK akredite)	€10.000 – €25.000	₺400.000 – ₺1.000.000	Yılda 1 kez tüm sistem bileşenleri
GRC/Uyumluluk Platformu (Vanta/Drata)	\$5.000 – \$20.000	₺180.000 – ₺720.000	Yıllık abonelik (opsiyonel)
SIEM/Log Yönetim Platformu	€3.000 – €15.000	₺120.000 – ₺600.000	Yıllık (self-hosted olursa sadece altyapı maliyeti)
Personel Farkındalık Eğitimi	€500 – €2.000	₺20.000 – ₺80.000	Platform aboneliği veya eğitmen ücreti
SSL/TLS Sertifikası (Wildcard)	€100 – €500	₺4.000 – ₺20.000	Let's Encrypt kullanılırsa ücretsiz

Kalem	Aralık (EUR)	Aralık (TL)	Açıklama
ISO 27001 Standart Dokümanı Lisansı	€129 – CHF 155	₺5.000 – ₺6.000	ISO/IEC 27001:2022 ve ISO/IEC 27002:2022 satın alma
Yıllık Yenilenen Toplam	€16.729 – €48.629	₺669.000 – ₺1.945.000	

A.3 3 Yıllık Sertifikasyon Döngüsü Toplamı

Yıl	Faaliyetler	Tahmini Maliyet (EUR)
Yıl 1	Stage 1+2, danışmanlık, eğitim, araç kurulumu, pentest	€35.000 – €110.000
Yıl 2	Surveillance audit, pentest, platform yenileme, eğitim	€15.000 – €45.000
Yıl 3	Surveillance audit, pentest, platform yenileme, re-certification hazırlığı	€20.000 – €55.000
3 Yıllık Toplam		€70.000 – €210.000
3 Yıllık Toplam (TL)		₺2.800.000 – ₺8.400.000

A.4 Tasarruf Stratejileri

Strateji	Tasarruf	Risk
Let's Encrypt (ücretsiz TLS)	€100-500/yıl	Sertifika yenileme otomasyonu kurulmalı
Self-hosted SIEM (ELK/Grafana)	€3.000-15.000/yıl	İşletim ve bakım iş yükü
GRC platformu kullanmama (manuel takip)	\$5.000-20.000/yıl	İş yükü artışı, insan hatası riski
Butik sertifikasyon kuruluşu (Büyük Dörtlü yerine)	€10.000-40.000 (3 yıl)	Müşteri tarafından daha az tanınabilir
İç denetimi dış kaynak yerine kendi eğitimli personelle yapma	€3.000-8.000/yıl	Bağımsızlık şartına dikkat edilmeli
NIS2 ve ISO 27001 pentestlerini birleştirme	€10.000-25.000/yıl	Kapsam genişlediği için pentest süresi uzayabilir

A.5 NIS2 ve ISO 27001 Ortak Maliyet Optimizasyonu

NIS2 ve ISO 27001'in aynı anda uygulanması bazı maliyetlerin birleştirilmesini sağlar:

Kalem	Ayrı Maliyet	Birleşik Maliyet	Tasarruf
Pentest	2 x €15.000 = €30.000/yıl	€18.000/yıl (birleşik kapsam)	€12.000/yıl
Danışmanlık	2 x €15.000 = €30.000	€20.000 (tek seferlik birleşik)	€10.000

Kalem	Ayrı Maliyet	Birleşik Maliyet	Tasarruf
SBOM/Trivy altyapısı	Paylaşımlı	Aynı CI pipeline'ı	%100
SonarQube profilleri	Paylaşımlı	Tek profil (NIS2+ISO kuralları)	%100
TamperEvidentLogger	Paylaşımlı	Tek logger (NIS2+ISO gereksinimleri)	%100
SIEM/Log platformu	Paylaşımlı	Tek platform	%100
Eğitim programları	Kısmen ayrı	Birleşik farkındalık eğitimi	%50

Ek B: NIS2-ISO 27001:2022 Kontrol Eşleştirme Matrisi

NIS2 Referansı	ISO 27001:2022 Annex A Kontrolü	Eşleşme Derecesi	Açıklama
Madde 21(2)(a) — Risk analizi ve güvenlik politikaları	A.5.1 Policies for information security	✓	NIS2 risk yönetimi, ISO'nun ISMS politikalarına karşılık gelir
Madde 21(2)(a) — Risk yönetimi	A.5.2-A.5.8 (Organizational controls)	✓	
Madde 21(2)(b) — Olay yönetimi	A.5.24-A.5.28 Incident management	✓	
Madde 21(2)(b) — Olay raporlama	A.6.8 Information security event reporting	✓	
Madde 21(2)(c) — İş sürekliliği ve kriz yönetimi	A.5.29, A.5.30 Business continuity / ICT readiness	✓	
Madde 21(2)(c) — Yedekleme	A.8.13 Information backup	⚠	ISO daha detaylı (test, şifreleme, saklama)
Madde 21(2)(d) — Tedarik zinciri güvenliği	A.5.19-A.5.22 Supplier relationships	✓	
Madde 21(2)(e) — Ağ ve bilgi sistemleri güvenliği	A.8.8, A.8.9, A.8.20-A.8.23	⚠	ISO daha geniş (network seg, web filtering)
Madde 21(2)(e) — Güvenlik testleri ve denetimleri	A.8.29, A.8.8	✓	
Madde 21(2)(f) — İK güvenliği ve erişim kontrolü	A.5.15-A.5.18 + A.6.1-A.6.8	✓	

NIS2 Referansı	ISO 27001:2022 Annex A Kontrolü	Eşleşme Derecesi	Açıklama
Madde 21(2)(f) — Sıfır güven ve kimlik doğrulama	A.8.2 Privileged access, A.8.5 Secure authentication	⚠️	ISO doğrudan "zero trust" demez ama PAM/çok faktörlü kimlik doğrulama ister
Madde 21(2)(g) — Kriptografi ve şifreleme	A.8.24 Use of cryptography	✅	
Madde 21(3) — Çok faktörlü kimlik doğrulama	A.8.5 Secure authentication	✅	
Madde 21(3) — Güvenli iletişim (acil durum)	A.5.13 Labelling of information	⚠️	ISO spesifik olarak acil durum iletişimini ayrıca ele almaz
ISO'ya Özel — Karşılığı NIS2'de Yok			
-	A.5.9 Inventory of information assets	❌	NIS2'de varlık envanteri zorunluluğu yok
-	A.5.10 Acceptable use of information	❌	
-	A.7.1-A.7.14 Physical controls	❌	NIS2 fiziksel güvenliği kapsamaz
-	A.8.12 Data leakage prevention	⚠️	NIS2'de kısmen (hard-coded secrets) var
-	A.8.16 Monitoring activities	⚠️	NIS2'de loglama var ama kapasite izleme yok
-	A.8.17 Clock synchronization	❌	NIS2'de saat senkronizasyonu zorunluluğu yok
-	A.8.19 Installation of software on operational systems	❌	NIS2'de Docker hardening yok
-	A.8.25-A.8.28 Secure development life cycle (tam SDLC)	⚠️	NIS2 SSDF var ama ISO tüm SDLC fazlarını kapsar
-	Clause 4-10 (ISMS yönetim sistemi)	❌	NIS2 bir yönetim sistemi standardı değildir

Lejant: ✅ Doğrudan örtüşüyor | ⚠️ Kısmen örtüşüyor (ISO daha kapsamlı) | ❌ ISO'ya özel, NIS2'de karşılığı yok

Monorepo Dizin Planı

Bu adımların uygulanması sonucunda workspace'te aşağıdaki ekleme ve değişiklikler yapılacaktır:

Yeni Eklenecek Dosyalar (Dokümantasyon):

- docs/policies/bilgi-guvenligi-politikasi.md
- docs/policies/isms-kapsam.md
- docs/policies/uygulanabilirlik-bildirgesi.md
- docs/policies/varlik-envanteri.md
- docs/policies/risk-degerlendirme-proseduru.md
- docs/policies/risk-isleme-planı.md
- docs/policies/guvenlik-rolleri.md
- docs/policies/erisim-kontrol-matrisi.md
- docs/policies/log-saklama-politikasi.md
- docs/policies/olay-mudahale-proseduru.md
- docs/policies/is-surekliligi-planı.md
- docs/policies/tedarikci-guvenlik-degerlendirme.md
- docs/policies/tedarikci-degerlendirme-formu.md
- docs/policies/farkindalik-egitim-planı.md
- docs/policies/gizlilik-sozlesmesi-taslagi.md
- docs/policies/ic-denetim-proseduru.md
- docs/policies/duzeltici-faaliyet-proseduru.md
- docs/policies/duzeltici-faaliyet-takip.md
- docs/policies/yonetim-gozden-gecirme-proseduru.md
- docs/policies/yedekleme-stratejisi.md
- docs/policies/yedekleme-test-kayitlari.md
- docs/policies/ygg-tutanaklari/ (dizin)
- docs/policies/tatbikat-kayitlari/ (dizin)

Güncellenecek / Yeni Eklenecek Dosyalar (Teknik):

- web-service/src/presentation/server.ts (helmet, rate-limit, TLS)
- demo-backend/src/infrastructure/api/server.ts (helmet, rate-limit, TLS)
- apps/container-web/deployment/nginx.conf (security headers, TLS)
- deployment/docker-compose.container.yml (TLS, ağ segmentasyonu, secrets)
- deployment/docker-compose.dev.yml (geliştirme ortamı TLS)
- Tüm Dockerfile'lar (non-root kullanıcı)
- .gitignore (.env.*, *.pem, *.key ekleme)
- sonar-project.properties (ISO ek kuralları)
- packages/core/src/lib/logger/tamper-evident-logger.ts (ISO ekleri: NTP offset, kapasite)
- scripts/backup.sh (yedekleme otomasyonu)
- CI/CD workflow (.github/workflows/) (Trivy image scan, lisans taraması)
- playwright.config.ts (security-headers testi)

Ek C: ISO 27001:2022 Annex A Kontrol Listesi (Özet)

ISO/IEC 27001:2022 Annex A, 4 tema altında toplam 93 kontrol içerir:

Tema	Kontrol Sayısı	Referanslar
A.5 Organizational controls	37	A.5.1 – A.5.37
A.6 People controls	8	A.6.1 – A.6.8
A.7 Physical controls	14	A.7.1 – A.7.14
A.8 Technological controls	34	A.8.1 – A.8.34

Bu döküman kapsamında GD-PMS için uygulanan kontrollerin tam listesi SoA (Uygulanabilirlik Bildirgesi) dokümanında yer alacaktır.

Bu belge, ISO/IEC 27001:2022 uyumluluk sürecinin GD-PMS monorepo yazılım geliştirme ve işletim ayağını kapsamaktadır. Kurumsal ağ güvenliği, ofis fiziksel güvenliği, İK özlük süreçleri ve kurumsal e-posta/ERP sistemleri bu ISMS kapsamı dışındadır. Belgelendirme süreci ve ISMS'in bütünsel kurulumu için ayrıca danışmanlık desteği önerilmektedir.